Universidad Tecnológica de Durango

A09 · Modelo de datos y consultas

Proyecto Alfa Baluarte: sistema de escritorio local para la clínica (Victoria de Durango)

Datos del documento

Campo	Dato
Asignatura	Proyecto Integrador I (E-PIN1-1)
Unidad	III. Diseño, aplicación, desarrollo y pruebas del proyecto
Actividad	A09 · Modelo de datos y consultas
Profesor	Raúl Iván Herrera González
Grupo	4B BIS TI · UT Durango
Equipo	Alfa Baluarte (Equipo 2)
Integrantes	Dylan Percy Rodriguez Sanchez Miguel Isai Escajeda Sariñana Karol Emmanuel Guerrero Quintero (Product Ownerr), Luis Alejandro Macias Salas Leonel Ivan Sifuentes Zaragoza
Proyecto	Sistema de escritorio para la clínica de Jessica Cisley: expediente integral digital de pacientes y personal
Archivo a entregar	Equipo02_A09_AlfaBaluarte.pdf (en /portafolio/A09/)
Scripts	01_ddl.sql, 02_dml.sql, 03_consultas.sql y 04_seguridad.sql en /db/ del repositorio, con README de ejecución en orden
Fecha de entrega	6 / 11 / 26

1. Selección del sistema gestor de base de datos

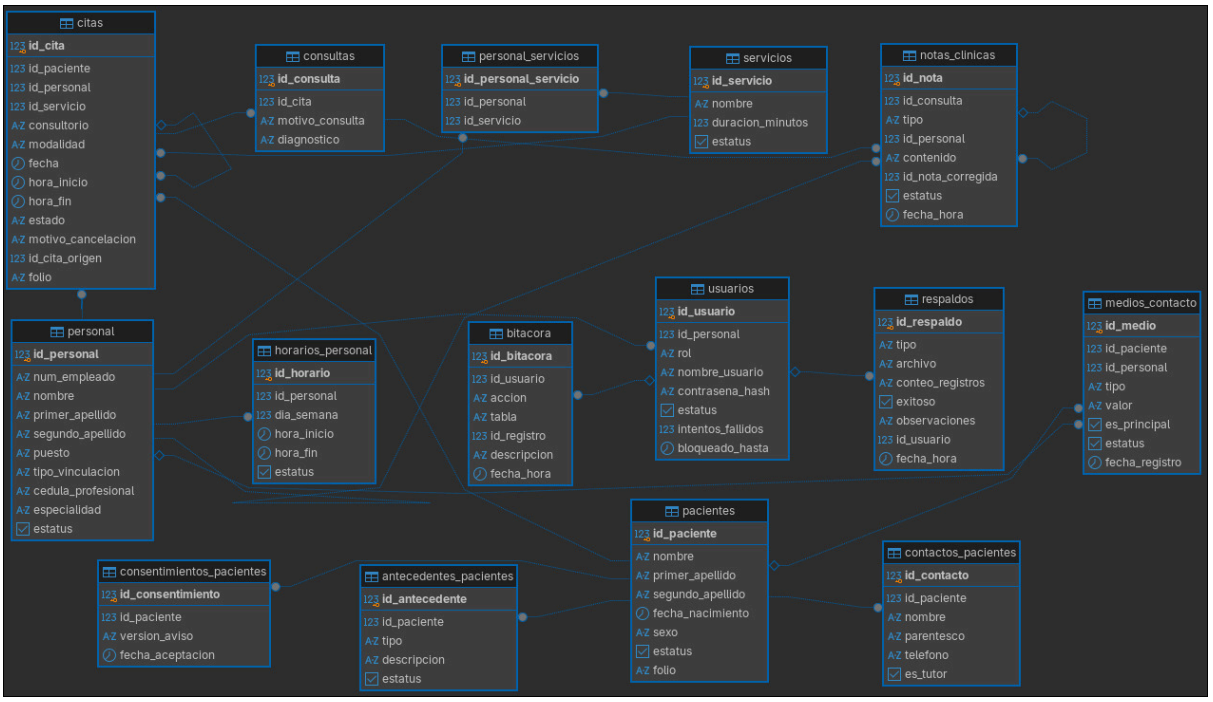
Criterio	Peso	Opción A: PostgreSQL	Opción B: MySQL
Conocimiento del equipo	2.5	4	3.5
Hosting disponible	5	2	5
Costo	5	5	5
Requerimientos del proyecto	3	2	4

Decisión y justificación:

Se ha determinado utilizar PostgreSQL como el motor de base de datos para este proyecto. Aunque el equipo de desarrollo cuenta con mayor experiencia previa trabajando con MySQL, actualmente nos encontramos estudiando PostgreSQL en clase. Esta decisión nos permite aplicar de manera práctica los nuevos conocimientos que estamos adquiriendo y contar con el respaldo académico directo del docente. Además, tras evaluar las características de ambos sistemas, consideramos que PostgreSQL es un motor de base de datos más robusto y avanzado, cuyas características relacionales y de integridad de datos lo convierten en una herramienta superior y más adecuada para estructurar la información clínica de este proyecto.

2. Modelo entidad-relación

[Imagen del diagrama entidad-relación]



Entidad	Atributos principales	Caso de uso de A08 que la necesita
Paciente	[redacted]	CU-01: Registrar nuevo paciente
Doctor *(Personal)*	id_personal, num_empleado, nombre, primer_apellido, segundo_apellido, puesto, tipo_vinculacion, cedula_profesional, especialidad, estatus	CU-02: Gestionar personal

Cita	id_cita, folio, id_paciente, id_personal, id_servicio, consultorio, modalidad, fecha, hora_inicio, hora_fin, estado, motivo_cancelacion, id_cita_origen	CU-03: Agendar y cancelar citas
Especialidad *(Servicios)*	id_servicio, nombre, duracion_minutos, estatus	CU-04: Asignar especialidades
Historial *(Consultas / Antecedentes)*	id_consulta, id_cita, motivo_consulta, diagnostico, id_antecedente, tipo, descripcion	CU-05: Consultar expediente médico

Relación	Entidad 1	Entidad 2	Cardinalidad	Regla de negocio (RN-__)
Solicita/Tiene	Paciente	Cita	1:N	RN-01: El paciente puede agendar múltiples citas a lo largo del tiempo, pero una cita pertenece a un solo paciente
Atiende	Doctor	Cita	1:N	RN-02: Un médico puede atender varias citas durante su turno, pero cada cita es asignada a un único médico.
Tiene	Doctor	Especialidad	N:M	RN-03: Un médico puede tener varias especialidades, y una especialidad puede tener varios médicos.
Registra	Paciente	Historial	1:1	RN-04: Un paciente tiene un único expediente

				clínico consolidado donde se guarda toda su información de salud.
Genera	Médico	Historial	1:N	RN-05: Un doctor puede generar varios registros o actualizaciones en los historiales de los distintos pacientes que atiende.

3. Modelo relacional normalizado

Transforma el modelo ER en tablas. Inserta el diagrama de tablas con llaves primarias (PK) y llaves foráneas (FK). Una relación N:M se convierte en una tabla intermedia.

[Imagen del diagrama relacional]

Evidencia de normalización

Muestra paso a paso (1FN, 2FN y 3FN) al menos una tabla que tenía problemas y explica cada cambio.

Tabla original (problema)	**1FN**	**2FN**	**3FN**	**Explicación (qué cambiaron y por qué)**
Personal_Original: id_personal nombre_completo puesto	Personal_1FN: id_personal (PK) servicio (PK)	Personal: id_personal (PK) nombre_completo	Personal: id_personal (PK) nombre...	Problema original: El campo servicios tenía listas separadas por comas. 1FN (Valores atómicos): Se dividió la lista creando múltiples filas por

servicios (Ej: Psicología, Terapia de pareja) duracion_servicio	nombre_completo puesto duracion_servicio	puesto Personal_Servicios: id_personal (PK/FK) servicio (PK) duracion_servicio	Servicios: id_servicio (PK) nombre_servicio duracion_minutos Personal_Servicios: id_personal (FK) id_servicio (FK)	cada servicio que da un empleado, formando una llave compuesta (id_personal, servicio). 2FN (Dependencia total): El nombre_completo dependía solo del id_personal, no del servicio. Se separó en dos tablas para no repetir el nombre del doctor. 3FN (Sin dependencias transitivas): La duracion_servicio dependía del servicio, no del doctor. Se creó la

				tabla independiente Servicios y una tabla intermedia Personal_Servicios para relacionarlos, llegando a la estructura final de tu código SQL.
Tabla original (problema)	**1FN**	**2FN**	**3FN**	**Explicación (qué cambiaron y por qué)**

4. Diccionario de datos

Documenta cada campo de cada tabla. Repite el bloque de filas por tabla. En Llave / restricción anota PK, FK (a qué tabla), UNIQUE, CHECK o DEFAULT.

Tabla	**Campo**	**Tipo**	**Longitud**	**Nulo**	**Llave / restricción**	**Descripción**
personal	id_personal	INT	-	No	PK	Identificador único del empleado
personal	num_empleado	VARCHAR	20	No	UNIQUE	Número de control interno del empleado

personal	nombre	VARCHAR	80	No	-	Nombre(s) del empleado
personal	primer_apellido	VARCHAR	60	No	-	Apellido paterno del empleado
personal	segundo_apellido	VARCHAR	60	Sí	-	Apellido materno del empleado
personal	puesto	VARCHAR	30	No	CHECK	Cargo que ocupa (Administración, Terapeuta, etc.)
personal	tipo_vinculacion	VARCHAR	25	No	DEFAULT, CHECK	Relación laboral (Empleado, Colaborador, etc.)
personal	cedula_profesional	VARCHAR	20	Sí	UNIQUE	Cédula profesional si aplica al puesto
personal	especialidad	VARCHAR	80	Sí	-	Especialidad médica o terapéutica
personal	estatus	BOOLEAN	-	No	DEFAULT	Indica si el empleado está activo
usuarios	id_usuario	INT	-	No	PK	Identificador único del usuario del sistema

usuarios	id_personal	INT	-	No	FK a personal, UNIQUE	Empleado al que pertenece la cuenta
usuarios	rol	VARCHAR	20	No	CHECK	Nivel de permisos en el sistema
usuarios	nombre_usuario	VARCHAR	50	No	UNIQUE, CHECK	Nombre para iniciar sesión
usuarios	contrasena_hash	VARCHAR	100	No	-	Contraseña encriptada
usuarios	estatus	BOOLEAN	-	No	DEFAULT	Indica si la cuenta está activa
usuarios	intentos_fallidos	INT	-	No	DEFAULT, CHECK	Contador de intentos de login erróneos
usuarios	bloqueado_hasta	TIMESTAMP	-	Sí	-	Fecha y hora de fin de bloqueo de cuenta
pacientes	id_paciente	INT	-	No	PK	Identificador único del paciente

pacientes	folio	VARCHAR	12	No	UNIQUE, CHECK	Folio generado automáticamente (PAC-XXXXXX)
pacientes	nombre	VARCHAR	80	No	UNIQUE compuesta	Nombre(s) del paciente
pacientes	primer_apellido	VARCHAR	60	No	UNIQUE compuesta	Apellido paterno del paciente
pacientes	segundo_apellido	VARCHAR	60	No	DEFAULT, UNIQUE comp.	Apellido materno del paciente
pacientes	fecha_nacimiento	DATE	-	No	CHECK, UNIQUE comp.	Fecha de nacimiento del paciente
pacientes	sexo	CHAR	1	Sí	CHECK	Sexo del paciente (F, M, O)
pacientes	estatus	BOOLEAN	-	No	DEFAULT	Indica si el paciente está activo

citas	id_cita	INT	-	No	PK	Identificador único de la cita
citas	folio	VARCHAR	12	No	UNIQUE, CHECK	Folio generado automáticamente (CIT-XXXXXX)
citas	id_paciente	INT	-	No	FK a pacientes	Paciente que agenda la cita
citas	id_personal	INT	-	No	FK a personal	Profesional que atenderá la cita
citas	id_servicio	INT	-	No	FK a servicios	Servicio a otorgar en la cita
citas	consultorio	VARCHAR	40	Sí	-	Consultorio o sala asignada
citas	modalidad	VARCHAR	10	No	DEFAULT, CHECK	Modalidad (Presencial o En línea)
citas	fecha	DATE	-	No	-	Fecha programada de la cita
citas	hora_inicio	TIME	-	No	-	Hora en que inicia la cita

citas	hora_fin	TIME	-	No	CHECK	Hora en que termina la cita
citas	estado	VARCHAR	15	No	DEFAULT, CHECK	Estatus actual de la cita
citas	motivo_cancelacion	VARCHAR	200	Sí	-	Razón por la que se canceló (si aplica)
citas	id_cita_origen	INT	-	Sí	FK a citas	ID de la cita original si fue reprogramada
servicios	id_servicio	INT	-	No	PK	Identificador único del servicio
servicios	nombre	VARCHAR	80	No	UNIQUE	Nombre del servicio o especialidad
servicios	duracion_minutos	INT	-	No	CHECK	Tiempo que dura la consulta en minutos
servicios	estatus	BOOLEAN	-	No	DEFAULT	Indica si el servicio está disponible
consultas	id_consulta	INT	-	No	PK	Identificador único de la consulta

consultas	id_cita	INT	-	No	FK a citas, UNIQUE	Cita a la que pertenece esta consulta
consultas	motivo_consulta	TEXT	-	No	CHECK	Motivo principal por el que acude el paciente
consultas	diagnostico	VARCHAR	300	Sí	-	Diagnóstico clínico determinado
notas_clinicas	id_nota	INT	-	No	PK	Identificador único de la nota
notas_clinicas	id_consulta	INT	-	No	FK a consultas	Consulta a la que pertenece la nota
notas_clinicas	tipo	VARCHAR	20	No	CHECK	Tipo de nota (inicial, evolucion, etc.)
notas_clinicas	id_personal	INT	-	No	FK a personal	Profesional que redacta la nota
notas_clinicas	contenido	TEXT	-	No	CHECK	Texto del expediente clínico
notas_clinicas	id_nota_corregida	INT	-	Sí	FK a notas_clinicas	Relación a una nota previa si es corrección

notas_clinicas	estatus	BOOLEAN	-	No	DEFAULT	Indica si la nota es válida y activa
notas_clinicas	fecha_hora	TIMESTAMP	-	No	DEFAULT	Fecha y hora de redacción
antecedentes_pacientes	id_antecedente	INT	-	No	PK	Identificador único del antecedente
antecedentes_pacientes	id_paciente	INT	-	No	FK a pacientes	Paciente al que pertenece el antecedente
antecedentes_pacientes	tipo	VARCHAR	20	No	CHECK	Categoría (alergias, familiares, etc.)
antecedentes_pacientes	descripcion	TEXT	-	No	CHECK	Detalle del antecedente
antecedentes_pacientes	estatus	BOOLEAN	-	No	DEFAULT	Indica si el registro está activo
contactos_pacientes	id_contacto	INT	-	No	PK	Identificador único del contacto de emergencia
contactos_pacientes	id_paciente	INT	-	No	FK a pacientes	Paciente al que pertenece el contacto

contactos_pacientes	nombre	VARCHAR	120	No	-	Nombre del contacto
contactos_pacientes	parentesco	VARCHAR	40	Sí	-	Relación con el paciente (Madre, Padre, etc.)
contactos_pacientes	telefono	VARCHAR	10	No	CHECK	Número de teléfono a 10 dígitos
contactos_pacientes	es_tutor	BOOLEAN	-	No	DEFAULT	Indica si el contacto es tutor legal
consentimientos_pacientes	id_consentimiento	INT	-	No	PK	Identificador del registro de consentimiento
consentimientos_pacientes	id_paciente	INT	-	No	FK a pacientes, UNIQUE	Paciente que firma el aviso
consentimientos_pacientes	version_aviso	VARCHAR	20	No	UNIQUE compuesta	Versión del aviso de privacidad aceptado
consentimientos_pacientes	fecha_aceptacion	DATE	-	No	DEFAULT	Fecha en que se aceptó el consentimiento

medios_contacto	id_medio	INT	-	No	PK	Identificador único del medio de contacto
medios_contacto	id_paciente	INT	-	Sí	FK a pacientes	Paciente asociado (si aplica)
medios_contacto	id_personal	INT	-	Sí	FK a personal	Personal asociado (si aplica)
medios_contacto	tipo	VARCHAR	10	No	CHECK	Tipo (telefono o correo)
medios_contacto	valor	VARCHAR	100	No	-	Número o dirección de correo
medios_contacto	es_principal	BOOLEAN	-	No	DEFAULT	Indica si es el medio de contacto principal
medios_contacto	estatus	BOOLEAN	-	No	DEFAULT	Indica si el medio de contacto está activo
medios_contacto	fecha_registro	TIMESTAMP	-	No	DEFAULT	Fecha en que se agregó el contacto
personal_servicios	id_personal_servicio	INT	-	No	PK	Identificador de la asignación

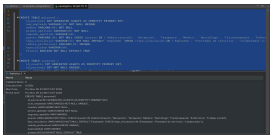
personal_servicios	id_personal	INT	-	No	FK a personal	Profesional asignado
personal_servicios	id_servicio	INT	-	No	FK a servicios	Servicio o especialidad asignada
horarios_personal	id_horario	INT	-	No	PK	Identificador único del bloque de horario
horarios_personal	id_personal	INT	-	No	FK a personal	Profesional dueño de este horario
horarios_personal	dia_semana	INT	-	No	CHECK	Día de 1 (lunes) a 7 (domingo)
horarios_personal	hora_inicio	TIME	-	No	UNIQUE compuesta	Hora en la que inicia su turno
horarios_personal	hora_fin	TIME	-	No	CHECK	Hora en la que termina su turno
horarios_personal	estatus	BOOLEAN	-	No	DEFAULT	Indica si este horario está activo
bitacora	id_bitacora	INT	-	No	PK	Identificador único del log

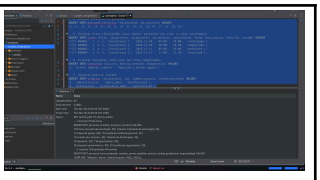
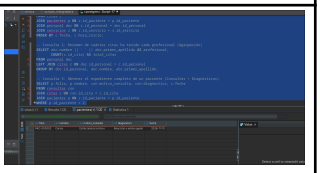
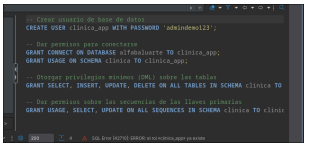
bitacora	id_usuario	INT	-	Sí	FK a usuarios	Usuario que realizó la acción
bitacora	accion	VARCHAR	20	No	CHECK	Operación realizada (alta, baja, etc.)
bitacora	tabla	VARCHAR	40	Sí	-	Tabla que fue afectada
bitacora	id_registro	INT	-	Sí	-	ID del registro que fue modificado
bitacora	descripcion	VARCHAR	300	Sí	-	Detalle de los cambios realizados
bitacora	fecha_hora	TIMESTAMP	-	No	DEFAULT	Fecha y hora del movimiento
respaldos	id_respaldo	INT	-	No	PK	Identificador del registro de respaldo
respaldos	tipo	VARCHAR	12	No	CHECK	Tipo de operación (respaldo o restauracion)
respaldos	archivo	VARCHAR	500	No	-	Ruta o nombre del archivo generado/usado

respaldos	conteo_registros	VARCHAR	500	Sí	-	Cantidad de datos respaldados por tabla
respaldos	exitoso	BOOLEAN	-	No	-	Indica si el proceso terminó sin errores
respaldos	observaciones	VARCHAR	300	Sí	-	Notas adicionales o errores presentados
respaldos	id_usuario	INT	-	Sí	FK a usuarios	Usuario que solicitó el respaldo
respaldos	fecha_hora	TIMESTAMP	-	No	DEFAULT	Fecha y hora en que se realizó

5. Scripts SQL

Enlaces a los scripts del repositorio (carpeta /db) y fragmentos relevantes. Agrega capturas de la ejecución sin errores. El DDL debe incluir PK, FK, NOT NULL, UNIQUE, CHECK y reglas ON DELETE / ON UPDATE justificadas. El DML necesita al menos 10 registros por tabla principal, datos anónimos y casos límite (por ejemplo, un usuario sin citas).

Script	Contenido	Enlace al repositorio	Captura de ejecución
01_ddl.sql	Creación de tablas y restricciones	https://github.com/miguel3142250004-hub/alfabaluarte/blob/main/sistema/database/01_ddl.sql	

02_dml.sql	Datos de prueba	https://github.com/miguel3142250004-hub/alfabaluarte/blob/main/sistema/database/02_dml.sql	
03_consultas.sql	Consultas de negocio, vista o procedimiento	https://github.com/miguel3142250004-hub/alfabaluarte/blob/main/sistema/database/03_consultas.sql	
04_seguridad.sql	Usuario de la aplicación con privilegios mínimos	https://github.com/miguel3142250004-hub/alfabaluarte/blob/main/sistema/database/04_seguridad.sql	

Justificación de ON DELETE y ON UPDATE

Llave foránea	ON DELETE	ON UPDATE	Por qué
usuarios.id_personal → personal.id_personal	CASCADE	NO ACTION	Si se elimina un registro de personal, su cuenta de usuario debe eliminarse automáticamente para no dejar credenciales huérfanas.
contactos_pacientes.id_paciente → pacientes.id_paciente	CASCADE	NO ACTION	Si un paciente es dado de baja, sus contactos de emergencia pierden

			sentido y deben borrarse en cascada.
citas.id_paciente → pacientes.id_paciente	RESTRICT	NO ACTION	Se impide eliminar a un paciente que tenga citas registradas para proteger la integridad del historial clínico.
citas.id_personal → personal.id_personal	RESTRICT	NO ACTION	Impide borrar a un médico o terapeuta si tiene citas asignadas, evitando que la agenda quede desatendida.
consultas.id_cita → citas.id_cita	CASCADE	NO ACTION	La consulta clínica depende enteramente de la cita; si la cita se elimina, la consulta se borra en cascada.
bitacora.id_usuario → usuarios.id_usuario	SET NULL	SET NULL	Si un usuario es eliminado del sistema, la bitácora conserva el registro de sus acciones asignando NULL al campo del usuario.

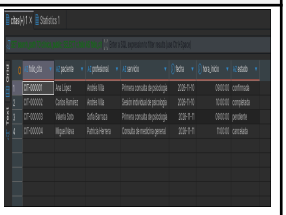
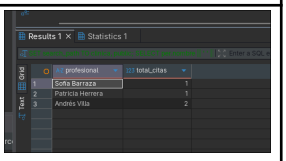
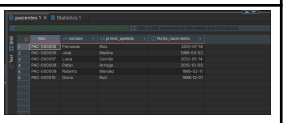
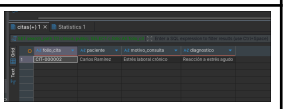
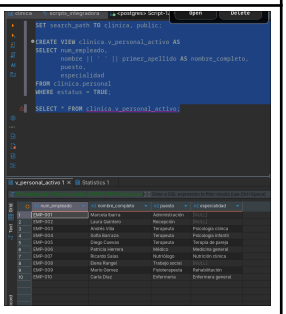
Fragmentos relevantes

```
-- pega aquí un fragmento del DDL que muestre PK, FK y CHECK
CREATE TABLE personal (
    id_personal INT GENERATED ALWAYS AS IDENTITY PRIMARY KEY,
    num_empleado VARCHAR(20) NOT NULL UNIQUE,
    nombre VARCHAR(80) NOT NULL,
    primer_apellido VARCHAR(60) NOT NULL,
    puesto VARCHAR(30) NOT NULL CHECK (puesto IN ('Administración', 'Recepción',
'Terapeuta', 'Médico', 'Nutriólogo', 'Fisioterapeuta', 'Enfermería', 'Trabajo social')),
    tipo_vinculacion VARCHAR(25) NOT NULL DEFAULT 'Empleado' CHECK
(tipo_vinculacion IN ('Empleado', 'Prestador de servicios', 'Colaborador')),
    cedula_profesional VARCHAR(20) UNIQUE
);

CREATE TABLE citas (
    id_cita INT GENERATED ALWAYS AS IDENTITY PRIMARY KEY,
    folio VARCHAR(12) NOT NULL UNIQUE,
    id_paciente INT NOT NULL,
    id_personal INT NOT NULL,
    id_servicio INT NOT NULL,
    consultorio VARCHAR(40),
    modalidad VARCHAR(10) NOT NULL DEFAULT 'Presencial',
    fecha DATE NOT NULL,
    hora_inicio TIME NOT NULL,
    hora_fin TIME NOT NULL,
    estado VARCHAR(15) NOT NULL DEFAULT 'pendiente',
    FOREIGN KEY (id_paciente) REFERENCES pacientes(id_paciente) ON DELETE
RESTRICT,
    FOREIGN KEY (id_personal) REFERENCES personal(id_personal) ON DELETE
RESTRICT,
    FOREIGN KEY (id_servicio) REFERENCES servicios(id_servicio) ON DELETE
RESTRICT
);
```

6. Consultas de negocio

Al menos 5 consultas que respondan necesidades de los casos de uso de A08. Debe haber una con JOIN de 3 tablas, una con GROUP BY y HAVING, una con subconsulta y una vista o un procedimiento almacenado. Cada integrante debe poder explicar cualquiera de ellas.

#	Pregunta de negocio	Caso de uso	Tipo (JOIN / GROUP BY / subconsulta / vista / procedimiento)	Captura del resultado
Q1	Q1 · ¿Cuál es el desglose completo de la agenda de citas con paciente, profesional asignado y servicio?	CU-01	JOIN de 4 tablas	
Q2	Q2 · ¿Qué profesionales han atendido una cantidad igual o mayor a 1 cita en el sistema?	CU-02	GROUP BY y HAVING	
Q3	Q3 · ¿Qué pacientes están registrados pero aún no han agendado ninguna cita?	CU-03	Subconsulta (NOT IN)	
Q4	Q4 · ¿Qué consultas médicas han sido completadas y qué diagnóstico se registró para el paciente?	CU-04	JOIN (consultas, citas, pacientes)	
Q5	Q5 · ¿Cómo obtener una vista reutilizable del directorio de personal activo en la clínica?	CU-05	Vista (CREATE VIEW)	

Q1 · (pregunta de negocio)

```
-- consulta
SET search_path TO clinica, public;

SELECT c.folio AS folio_cita,
       p.nombre || ' ' || p.primer_apellido AS paciente,
       per.nombre || ' ' || per.primer_apellido AS profesional,
       s.nombre AS servicio,
       c.fecha,
       c.hora_inicio,
       c.estado
FROM clinica.citas c
JOIN clinica.pacientes p ON c.id_paciente = p.id_paciente
JOIN clinica.personal per ON c.id_personal = per.id_personal
JOIN clinica.servicios s ON c.id_servicio = s.id_servicio
ORDER BY c.fecha, c.hora_inicio;
```

Q2 · (pregunta de negocio)

```
-- consulta
SET search_path TO clinica, public;

SELECT per.nombre || ' ' || per.primer_apellido AS profesional,
       COUNT(c.id_cita) AS total_citas
FROM clinica.personal per
JOIN clinica.citas c ON per.id_personal = c.id_personal
GROUP BY per.id_personal, per.nombre, per.primer_apellido
HAVING COUNT(c.id_cita) >= 1;
```

Q3 · (pregunta de negocio)

```
-- consulta
SET search_path TO clinica, public;

SELECT folio, nombre, primer_apellido, fecha_nacimiento
FROM clinica.pacientes
WHERE id_paciente NOT IN (
   SELECT DISTINCT id_paciente
   FROM clinica.citas
);
```

Q4 · (pregunta de negocio)

```
-- consulta
SET search_path TO clinica, public;

SELECT c.folio AS folio_cita,
       p.nombre || ' ' || p.primer_apellido AS paciente,
       con.motivo_consulta,
       con.diagnostico
FROM clinica.consultas con
JOIN clinica.citas c ON con.id_cita = c.id_cita
JOIN clinica.pacientes p ON c.id_paciente = p.id_paciente;
```

Q5 · (pregunta de negocio)

```
-- consulta
SET search_path TO clinica, public;

CREATE VIEW clinica.v_personal_activo AS
SELECT num_empleado,
       nombre || ' ' || primer_apellido AS nombre_completo,
       puesto,
       especialidad
FROM clinica.personal
WHERE estatus = TRUE;

SELECT * FROM clinica.v_personal_activo;
```

7. Seguridad informática de los datos

Las 4 medidas deben tener evidencia (captura, fragmento de código o script).

Medida	Cómo se aplica en nuestro proyecto	Evidencia
Hash de contraseñas (bcrypt o Argon2)	Las contraseñas de los usuarios jamás se guardan en texto plano. En el backend de Python se procesan con la librería `bcrypt` antes de insertarse en la base de datos, almacenando únicamente el hash resultante en el campo `contrasena_hash`.	Campo `contrasena_hash VARCHAR(100)` definido en la tabla `usuarios` (`01_ddl.sql`) y función `bcrypt.hashpw()` en el código de registro.
Usuario con privilegios mínimos	Se creó el rol de base de datos `clinica_app` utilizado exclusivamente por la aplicación. Solo tiene permisos DML (`SELECT`, `INSERT`, `UPDATE`, `DELETE`) sobre el esquema `clinica`, impidiendo la modificación de la estructura o borrado de tablas (`DROP`, `ALTER`).	Comandos `GRANT SELECT, INSERT, UPDATE, DELETE ON ALL TABLES IN SCHEMA clinica TO clinica_app;` contenidos en el script `04_seguridad.sql`.
Consultas parametrizadas (contra inyección SQL)	En la capa de acceso a datos de Python (`psycopg2`), todas las peticiones a la base de datos utilizan marcadores de posición (`%s`) enviando los parámetros en tuplas separadas del comando SQL.	Código de los repositorios (`src/repositories/`) donde se ejecuta `cursor.execute(query, (param1, param2))`.
Plan de respaldo	Se establece una estrategia de respaldos periódicos mediante la herramienta nativa `pg_dump` de PostgreSQL para generar respaldos de la estructura y datos ante cualquier eventualidad.	Ejecución del comando `pg_dump -U postgres -d alfabaluarte > respaldo.sql` y registros en la tabla `respaldos`.

Consulta vulnerable frente a consulta parametrizada

Muestra en el lenguaje del proyecto una consulta vulnerable y la misma consulta corregida, y explica por qué la primera permite inyección SQL.

Vulnerable
(código)

usuario_input = input("Usuario: ") password_input = input("Contraseña: ") query = f"SELECT * FROM clinica.usuarios WHERE nombre_usuario = '{usuario_input}' AND contrasena_hash = '{password_input}';" cursor.execute(query)

Parametrizada
(código)

```
usuario_input = input("Usuario: ")
password_input = input("Contraseña: ")

query = "SELECT * FROM clinica.usuarios WHERE nombre_usuario = %s AND contrasena_hash = %s;"
cursor.execute(query, (usuario_input, password_input))
```

Plan de respaldo

Frecuencia	Destino	Responsable
Diaria (Incremental al cierre de jornada - 20:00 hrs) Semanal (Completa los domingos - 02:00 hrs)	Servidor local de almacenamiento secundario (`/var/backups/pg_clinica`) y copia en repositorio privado de respaldo en la nube.	Administrador de Base de Datos (DBA) / Encargado de TI del proyecto.

8. Revisión crítica del modelo

Responde con honestidad. Si la respuesta indica un problema, anota qué corrección aplicaron.

Pregunta	Sí / No	Corrección
¿Hay datos repetidos en más de una tabla?	No	El modelo cumple con la Tercera Forma Normal (3NF). Se eliminó la redundancia asignando llaves primarias únicas y referenciando la información de pacientes, personal y servicios mediante llaves foráneas sin duplicar atributos.
¿Algún ON DELETE CASCADE puede borrar información valiosa?	No	Se protegió el historial médico. La regla `CASCADE` solo aplica en tablas dependientes secundarias (como `contactos_pacientes` o `usuarios`). Para tablas críticas como `citas` o `consultas` se configuró `RESTRICT` para evitar el borrado de información clínica.
¿Guardamos datos personales que no necesitamos?	No	Se aplicó el principio de minimización de datos. Solo se almacenan los campos indispensables para la operación médica, legal e identificación (nombre, fecha de nacimiento, sexo y medios de contacto básicos).
¿Todas las consultas de los casos de uso se pueden responder?	Si	No se requiere corrección. El esquema relacional cuenta con todos los atributos y llaves foráneas necesarios para resolver íntegramente las necesidades operativas descritas en los casos de uso (CU-01 a CU-05).

9. Referencias y declaración de uso de IA

Referencias

- Clark, W. (2020). *Metodología Ágil: Una guía para principiantes sobre el método y los principios ágiles*. Independently Published.
- DBeaver Corporation. (2026). *DBeaver documentation and user guide*. https://dbeaver.io/docs/
- OWASP Foundation. (s.f.). *SQL Injection Prevention Cheat Sheet*. OWASP Cheat Sheet Series. https://cheatsheetseries.owasp.org
- PostgreSQL Global Development Group. (2026). *PostgreSQL 16 Documentation*. https://www.postgresql.org/docs/
- JGraph Ltd. (2026). *Diagrams.net (draw.io) diagramming software*. https://app.diagrams.net

Declaración de uso de IA

Herramienta	Para qué se usó	Sección
Gemini / Claude	Diagnóstico y resolución de errores sintácticos de ejecución en PostgreSQL (resolución de conflictos de `search_path` y detección de relaciones de esquemas).	Sección 5 (Scripts)
Gemini / Claude	Revisión de sintaxis SQL para simplificar el DDL al nivel académico solicitado (eliminación de *triggers* e índices complejos manteniendo la integridad en 3NF).	Sección 3 (Normalización) y Sección 5 (Scripts)
Gemini / Claude	Apoyo en la estructuración, redacción técnica y formato Markdown para las tablas de documentación.	Sección 6 (Consultas de negocio) y Sección 7 (Seguridad)